INSTITUTO FEDERAL GOIANO - CAMPUS CERES

Curso: Bacharelado em Sistemas de Informação
Disciplina: Segurança da Informação
Docente: Prof. Roitier Campos Gonçalves
Discente: Marcos Felipe Pessoa

Relatório Técnico: Infraestrutura Segmentada e Firewall com Docker

1. Definição do Case

O cenário prático escolhido para este projeto é o **GlowAgenda**, um sistema web de gestão e agendamento voltado para salões de beleza e barbearias.

O contexto do negócio exige que as estações de trabalho físicas localizadas na recepção dos estabelecimentos (Rede Cliente/LAN) acessem a aplicação web para marcar horários e gerenciar clientes. A aplicação web, por sua vez, consome os dados armazenados em um banco de dados relacional. Para garantir a segurança dos dados dos clientes, os serviços foram segmentados. O servidor web e o banco de dados foram alocados em uma Zona Desmilitarizada (DMZ), separada fisicamente (via isolamento de rede virtual) da rede por onde os funcionários navegam.

2. Diagnóstico: Cenário Atual vs. Proposta de Solução

Cenário Atual (Problemas Mapeados):

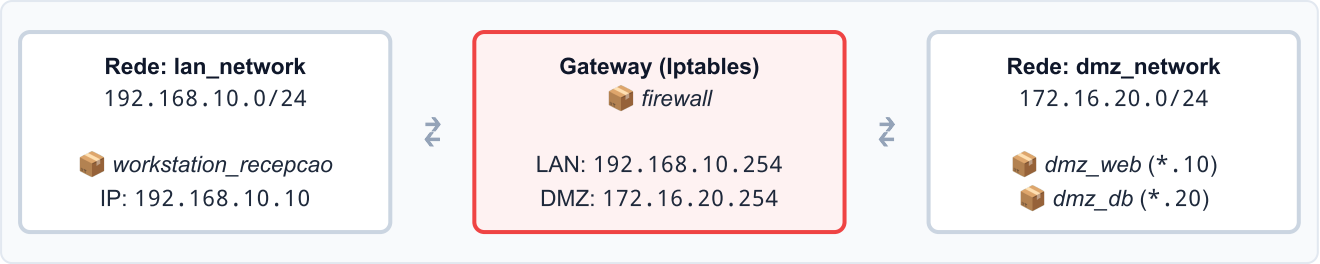
No cenário sem segmentação (rede plana), as máquinas da recepção compartilhavam o mesmo barramento de rede do banco de dados e do servidor web. Isso gerava uma vulnerabilidade crítica: em caso de infecção por malware em um computador da recepção ou acesso malicioso interno, o invasor teria comunicação direta com a porta 3306 do banco de dados, facilitando ataques de força bruta, injeção ou extração de dados sensíveis.

Proposta de Solução:

Para mitigar esse risco, a infraestrutura foi reestruturada utilizando a tecnologia de containers (Docker) com a seguinte arquitetura:

- **Segmentação:** Criação de duas redes isoladas (`192.168.10.0/24` para a LAN e `172.16.20.0/24` para a DMZ).
- **Gateway Centralizado:** Implementação de um container com função exclusiva de Roteador/Firewall entre as redes, com permissões elevadas.
- **Segurança de Borda:** Utilização do `iptables` no gateway para aplicar a filosofia *Zero Trust*, definindo a política padrão como DROP.

Diagrama da Arquitetura de Rede



3. Matriz de Regras de Segurança (Firewall)

As regras aplicadas no `iptables` refletem as necessidades de acesso do sistema, conforme tabela abaixo:

Origem	Destino	Porta/Protocolo	Ação	Justificativa do Negócio
Qualquer	Qualquer	Todos	**DROP**	**Política Padrão:** Todo o tráfego de repasse (FORWARD) entre as redes é descartado por padrão.
DMZ (Qualquer)	LAN	Qualquer (Retorno)	**ACCEPT**	**Retorno de Conexão:** Permite o retorno de pacotes de conexões iniciadas legitimamente pela rede Cliente.
Rede Cliente (LAN)	DMZ (Web) `172.16.20.10`	TCP 80	**ACCEPT**	Permite que a estação de trabalho da recepção acesse a interface web do sistema GlowAgenda.
Rede Cliente (LAN)	DMZ (DB) `172.16.20.20`	TCP 3306	**DROP**	**Bloqueio Explícito:** Garante que a LAN jamais acesse o banco de dados diretamente. Apenas o servidor Web tem privilégio.

4. Metodologia de Testes e Validação

O ambiente foi empacotado via Docker Compose para garantir reprodutibilidade. Para testar o ambiente, o avaliador deve executar os seguintes passos:

Passo 1: Inicialização do Ambiente

Na raiz do repositório, onde se encontra o arquivo `docker-compose.yml`, execute o comando de orquestração para inicializar a topologia de rede e os containers:

```
docker-compose up -d
```

Passo 2: Teste Positivo (Comunicação Permitida)

Para validar se a estação da recepção consegue acessar o sistema web na DMZ, simulamos uma requisição HTTP a partir do container cliente.

```
docker exec workstation_recepcao curl -I http://172.16.20.10
```

Resultado Esperado: O servidor responderá com o cabeçalho `HTTP/1.1 200 OK`, comprovando que o Firewall roteou e permitiu o pacote na porta 80.

Passo 3: Teste Negativo (Comunicação Bloqueada)

Para validar o isolamento do banco de dados, simulamos uma varredura de portas originada da recepção para o servidor de banco de dados na DMZ.

```
docker exec workstation_recepcao nmap -Pn -p 3306 172.16.20.20
```

Resultado Esperado: O Nmap reportará a porta `3306/tcp` como `filtered`. Isso comprova que o pacote foi descartado silenciosamente (DROP) pelo Firewall, impedindo qualquer tentativa de conexão direta ao SGBD.